

Contents

1	FUT01: 運営者サブロール	1
1.1	0. 文書情報	1
1.2	1. 概要	1
1.3	2. 関連要件・候補	1
1.3.1	2.1 要件候補 (将来 FR)	1
1.3.2	2.2 基本設計論点	2
1.3.3	2.3 詳細設計バックログ	2
1.4	3. 影響範囲	2
1.5	4. 実施条件	2
1.6	5. 関連設計	3
1.7	6. 未確定事項・確認事項	3

1 FUT01: 運営者サブロール

1.1 0. 文書情報

項目	内容
文書名	FUT01: 運営者サブロール
将来対応 ID	FUT-01
対象システム	FAQ AI ウィジェット SaaS / 運営者システム
作成日	2026-05-17
版数	v1.0
ステータス	検討中 (MVP 外)

1.2 1. 概要

項目	内容
概要	MVP では単一 service_operator ロールで運用している運営者ロールを、Post-MVP で職務分掌に応じたサブロール (billing_only / audit_read_only / support_operator / security_admin) へ分割する。
背景	運営者人数の拡大、内部統制レビュー、サポート運用と監査・課金運用の分離ニーズが顕在化した時点で、最小権限原則に基づく役割分担が必要となる。利用者側は MVP v2.5 でオーナー＋メンバー権限フラグ式に分割済みのため、本項は運営者ロール側の分割のみを扱う。
期待効果	最小権限原則の徹底、職務分掌違反リスクの低減、サポート業務と高権限業務の分離、監査ログの role / subrole 粒度向上。
優先度 (将来対応内)	中
想定時期	Post-MVP

1.3 2. 関連要件・候補

1.3.1 2.1 要件候補 (将来 FR)

1.3.1.1 認証・セキュリティ (運営者関連分)

ID	要件候補	MVP の前提	判定時期	判定基準 / 完了条件
FUT-REQ-SEC-004	運営者サブロール分割	単一 service_operator ロール (利用者側は MVP v2.5 でオーナー＋メンバー権限フラグ式に分割済み。本項は運営者ロール側の分割のみを扱う)	Post-MVP	運営者人数、職務分掌要件、内部統制レビュー、サポート運用の分離ニーズで導入可否を判定

1.3.2 2.2 基本設計論点

1.3.2.1 認証・セキュリティ (運営者関連分)

項目	基本設計で具体化すること	関連 Future 要件
運営者サブロール分割	権限マトリクス、メニュー表示制御、API 認可境界、監査ログの role / subrole 記録粒度	FUT-REQ-SEC-004

1.3.3 2.3 詳細設計バックログ

1.3.3.1 運営者サブロール (DDL 候補)

```
CREATE TABLE operator_subroles (  
  id TEXT PRIMARY KEY,  
  operator_id TEXT NOT NULL,  
  subrole TEXT NOT NULL,  
  granted_at TEXT NOT NULL,  
  granted_by TEXT NOT NULL,  
  revoked_at TEXT,  
  FOREIGN KEY (operator_id) REFERENCES service_operators(id),  
  FOREIGN KEY (granted_by) REFERENCES service_operators(id),  
  CHECK (subrole IN ('billing_only', 'audit_read_only', 'support_operator', 'security_admin'))  
);
```

```
CREATE INDEX idx_operator_subroles_operator  
ON operator_subroles(operator_id, revoked_at);
```

1.3.3.2 実装設計バックログ (運営者関連分)

ID	対象	実装設計で具体化すること	関連 Future 要件
FUT-DD-SEC-004	運営者サブロール	operator_subroles 相当テーブル、認可ミドルウェア、メニュー制御、監査ログ role snapshot	FUT-REQ-SEC-004

1.4 3. 影響範囲

種別	影響内容
要件	認証・認可 FR(運営者ロール定義)、監査ログ FR(role / subrole 記録粒度)、6 段認可判定の追加段 (subrole レベル)
画面	運営者ホーム (SCR-HOME)・各機能画面のメニュー表示制御、SCR-APPROVALS(承認権限の subrole 制限)、運営者管理画面 (subrole 割当 UI)
API	/admin/v1/* 全 API での subrole 認可ミドルウェア、POST /admin/v1/operators/{id}/subroles 等の subrole 管理 API
テーブル	operator_subroles、audit_logs.subrole_snapshot 列追加 (監査ログ正本の運営者システムで対応)
運用	subrole 割当・剥奪手順、最小権限レビュー (月次 / 四半期)、subrole 別 SLA、緊急例外時の subrole 一時昇格手順 (RB-014 連携)

1.5 4. 実施条件

項目	内容
実施判断条件	運営者人数の拡大 (目安: 10 名以上)、職務分掌要件、内部統制レビュー結果、サポート運用と高権限業務の分離ニーズ
期限	Post-MVP(導入可否判定を継続)

項目	内容
依存関係	共有概念の 4-eyes 承認基盤 (運営者正本)・ハッシュチェーン監査 (運営者正本) との整合、運営者システム 09 認証認可設計書の 6 段認可判定拡張

1.6 5. 関連設計

種別	参照先
要件	../01_ 要件定義/index.md
基本設計	../02_ 基本設計/index.md
詳細設計	../03_ 詳細設計/index.md
運用設計	../04_ 運用設計/index.md
共有概念 (正本)	../共有/共有概念.md

1.7 6. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
FUT-OP-SUB-Q-001	サブロール 4 種 (billing_only / audit_read_only / support_operator / security_admin) の権限マトリクス確定	高	検討中
FUT-OP-SUB-Q-002	既存 service_operator ロールから subrole 体系への移行手順 (全員 security_admin 暫定割当 → 段階剥奪)	中	検討中
FUT-OP-SUB-Q-003	緊急時の subrole 一時昇格手順 (RB-014 物理金庫連携の要否)	中	検討中
FUT-OP-SUB-Q-004	監査ログ subrole_snapshot のハッシュチェーン正本での扱い	中	検討中